COBIT

FURB
UNIVERSIDADE DE BLUMENAU

COBIT

- Um modelo que é amplamente adotado para atender à legislação SOX é o COBIT (Objetivos de controle para a informação e tecnologia - *Control Objectives for Information and Related Technology*)

- COBIT aplica diversas práticas no controle de informação. Vão desde o planejamento, qualidade de software, níveis de maturidade, segurança da informação até o monitoramento de resultados.

- "COBIT é um guia estruturado como framework, orientado a processos, que apresenta objetivos de controle a serem aplicados desde o planejamento da TI até a sua avaliação, de forma a ajudar no gerenciamento da TI, maximizando o retorno sobre seus investimentos"

Missão do COBIT

- Fornecer uma forma concreta da empresa implementar o alinhamento entre os objetivos de negócio e os objetivos da TI
- Ajudar a alcançar a conformidade regulatória pois utiliza controles utilizados por órgãos reguladores ou auditores externos
- Ser compatível com boas práticas, normas e padrões de TI mais reconhecidos e utilizados no mundo
- Ser independente de quaisquer tecnologias
- Ser um modelo orientado a processos com uma estrutura que perita fácil navegação e pesquisa pelo seu conteúdo
- Fornecer uma linguagem que utilize termos e definições que sejam que passam a formar o vocabulário dos profissionais de TI e demais gestores de negócio

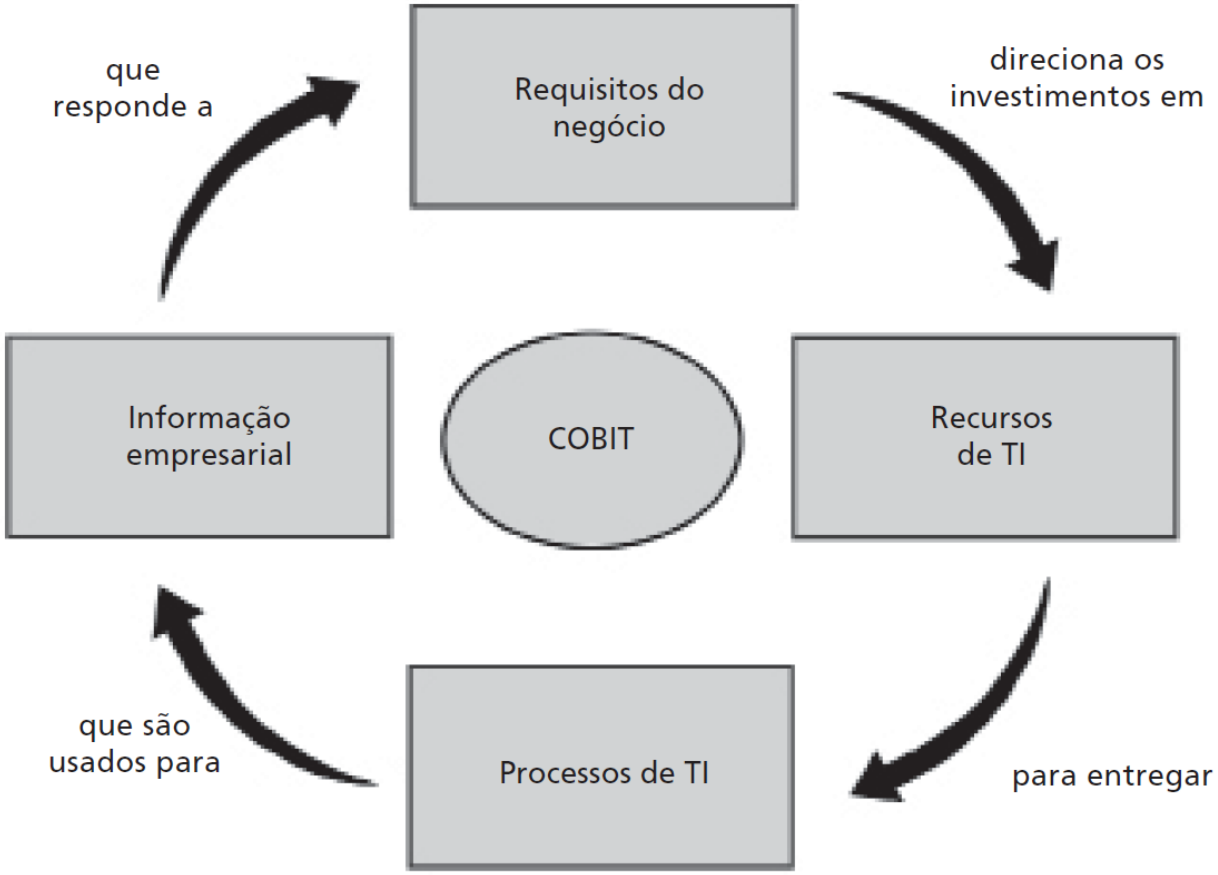
Sobre o COBIT

- Mais focado em objetivos de negócio
  - Conteúdo altamente abrangente
- Pouco detalhado sobre como os processos devem ser implementados
  - Contém muito sobre **o que** deve ser feito e **para que** deve ser feito
  - Contém pouca informação sobre **como** deve ser feito

Sobre o COBIT

- Público alvo do COBIT:
  - Gerentes que necessitam avaliar o risco e controlar os investimentos de TI em uma organização.
  - Usuários que precisam ter garantias de que os serviços de TI que dependem os seus produtos e serviços para os clientes internos e externos estão sendo bem gerenciados.
  - Auditores que podem se apoiar nas recomendações do COBIT para avaliar o nível da gestão de TI e aconselhar o controle interno da organização.

Ciclo básico do COBIT



Ciclo básico do COBIT

- Para o COBIT, os recursos da TI são:
  - Aplicações
  - Informação
  - Infraestrutura
  - Pessoas

Critérios de informação

- Para satisfazer os objetivos do negócio, a informação precisa ser adequada a certos critérios de controle. Estes critérios são chamados de **requisitos de negócio para a informação.**
- Existem 7 requisitos de negócio para a informação:
- **Eficácia**
  - A informação processada é aquela que realmente precisa ser processada para manter o negócio
- **Eficiência**
  - Os recursos estão sendo utilizados para processar a informação necessária?
- **Confidencialidade**
  - Garantia de que a informação sensível será protegida contra acessos não autorizados

Critérios de informação

- **Integridade**
  - Garantia de que a informação fornecida será exata e completa
- **Disponibilidade**
  - Garantia de que a informação necessária estará disponível no momento em que ela for necessária
- **Conformidade**
  - Garante que a informação atenda aos objetivos da legislação pertinente e aos arranjos contratuais. Trata de fatores externos, tais como normas, leis, contratos, etc.
- **Confiabilidade**
  - Garante que a informação necessária será gerada de maneira apropriada para que os responsáveis pelo negócio possam desempenhar o seu papel e cumprir as suas responsabilidades

Objetivos genéricos de todos os processos do COBIT

- PC1 – Objetivos e metas de processo
- PC2 – Propriedade do processo
- PC3 – Repetitividade do processo
- PC4 – Papéis e responsabilidades
- PC5 – Política, planos e procedimentos
- PC6 – Melhoria de desempenho do processo.

Domínios do COBIT

- COBIT é organizado em quatro áreas, conhecidas como “domínios do COBIT”, que são:
  - Planejamento e organização
  - Aquisição e implementação
  - Entrega e suporte
  - Monitoração

Planejamento e organização

- Lidam com questões como:
  - A TI e a estratégia do negócio estão alinhadas?
  - A empresa está atingindo um ótimo uso de seus recursos?
  - Todos na empresa entendem as metas e objetivos da TI?
  - Os riscos para a TI são entendidos e gerenciados?
  - A qualidade dos sistemas de TI é adequada às necessidades do negócio?

Aquisição e implementação

- Processo deste domínio buscam responder questões como:
  - Os novos projetos são selecionados de forma a entregar produtos e serviços que satisfaçam às metas de negócio?
  - Os novos projetos são selecionados de forma a entregar produtos e serviços no tempo acordado e dentro do orçamento?
  - Os novos produtos e serviços, quando em produção, atenderão às funcionalidades inicialmente previstas pelo usuário?
  - As mudanças no ambiente de produção serão feitas sem impactos nos negócios em andamento?

Entrega e suporte

- Os processos deste domínio lidam com questões como:
  - Os serviços de TI estão sendo entregues de acordo com as prioridades do negócio?
  - Os custos da TI estão sendo otimizados?
  - A força de trabalho é capaz de usas os sistemas de TI de forma segura e produtiva?
  - São garantidos os princípios de segurança da informação como a confidencialidade, a integridade e a disponibilidade?

Monitoração

- Os processos deste domínio lidam diretamente com questões como:
  - O desempenho da TI é medido para detectar problemas antes que seja tarde demais?
  - O gerenciamento assegura que os controles internos são eficientes e eficazes?
  - Os resultados da TI podem ser mapeados em metas de negócios?
  - Existem controles adequados à segurança da informação com relação à confidencialidade, integridade e disponibilidade?

COBIT

- Por meio de auditoria é possível verificar o nível de maturidade dos processos da organização, que seguem o modelo do CMM:

Nível	Descrição
Inexistente	O processo de gerenciamento não foi implantado
Inicial	O processo é realizado sem organização, de modo não planejado
Repetível	O processo é repetido de modo intuitivo, isto é, depende mais das pessoas do que de um método estabelecido
Definido	O processo é realizado, documentado e comunicado na organização
Gerenciado	Existem métricas de desempenho das atividades, o processo é monitorado e constantemente avaliado
Otimizado	As melhores práticas de mercado e automação são utilizadas para a melhoria contínua dos processos

Histórico do COBIT

- Primeira publicação em 1996 – Versão 1
  - Foco em auditoria e controle de sistemas de informação
- Versão 2 – 1998
- Versão 3 – 2000
  - Torna COBIT compatível com diversos outros frameworks, inclusive ITIL, PMBOK
- Versão 4 – 2005
  - Governança em TI
- Versão 4.1 – 2007
  - Revisão dos objetivos de controle
- Versão 5 – 2012
- Versão 2019

Estrutura do Cobit 2019

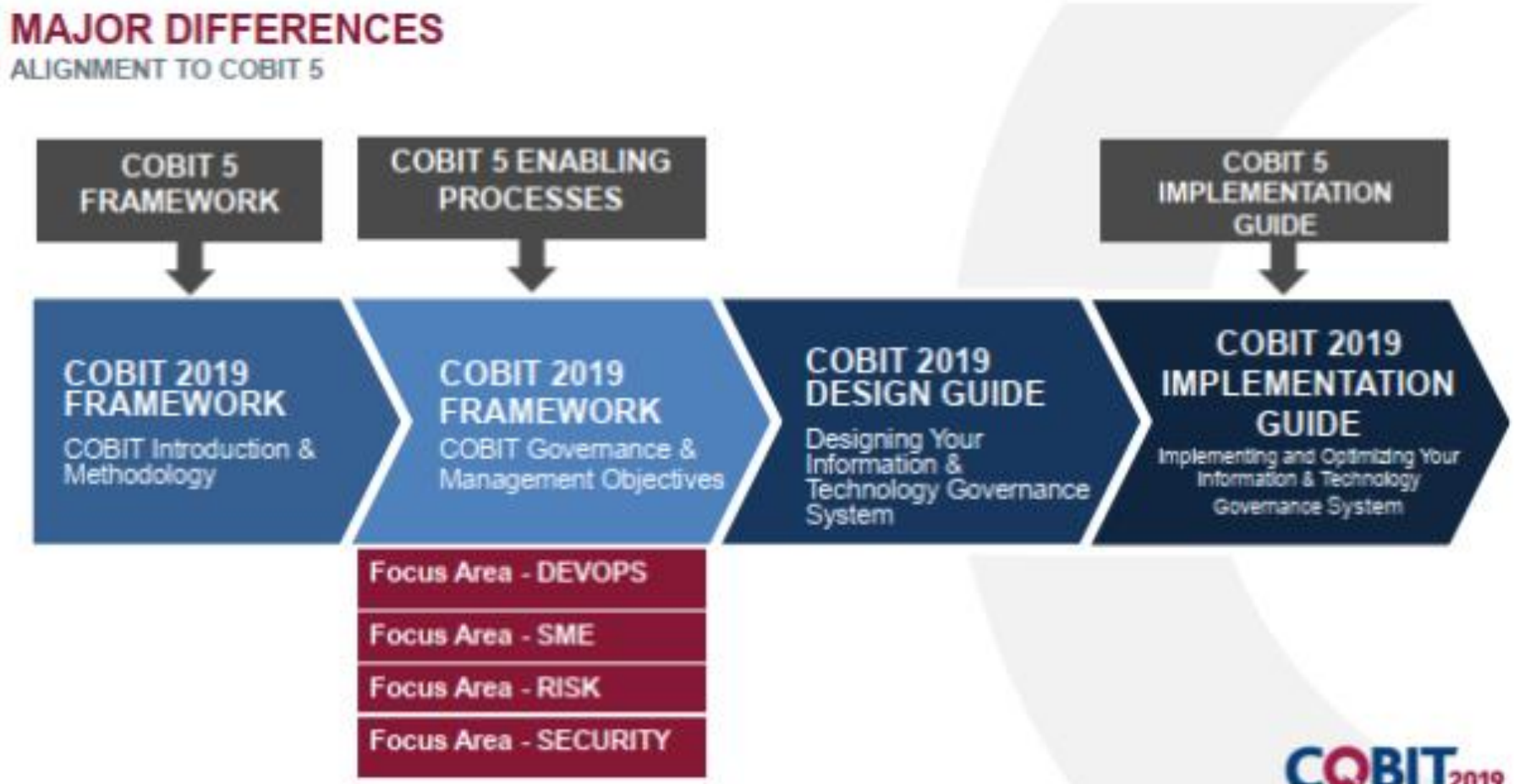
- Cobit 2019 *framework*: o guia principal que introduz os princípios básicos do Cobit

- Cobit 2019 *framework*: guia complementar que entra no modelo principal do Cobit e nos 40 objetivos de governança e gerenciamento

- Cobit 2019 *Implementation Guide*: guia complementar de orientação dos negócios por meio da implementação de governança

Cobit 2019 *Design Guide*: guia complementar referente como criar um sistema de governança sob medida

Maiores diferenças entre o Cobit 2019 e o Cobit 2005



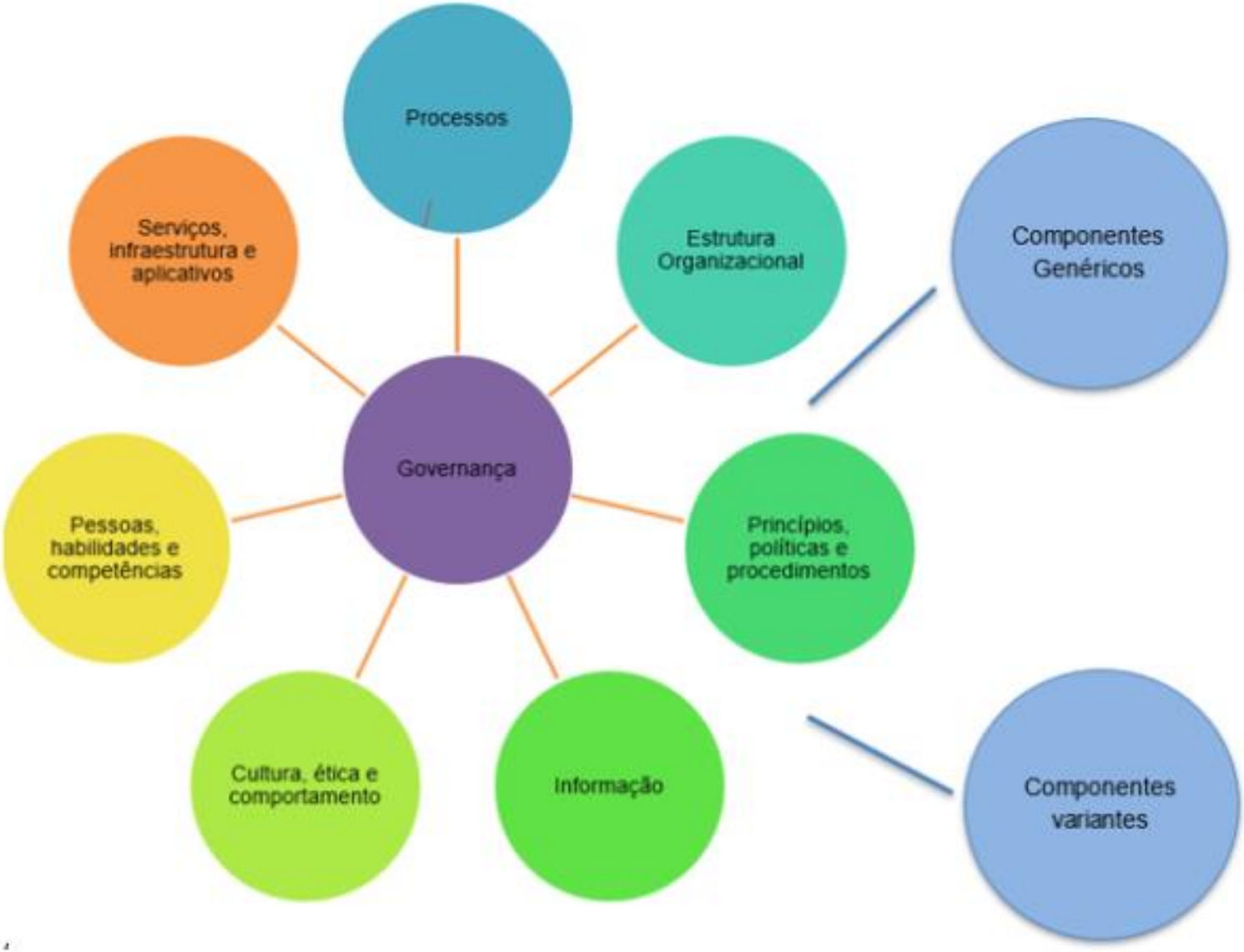
© 2019 ISACA. All rights reserved.

Princípios do Sistema de Governança

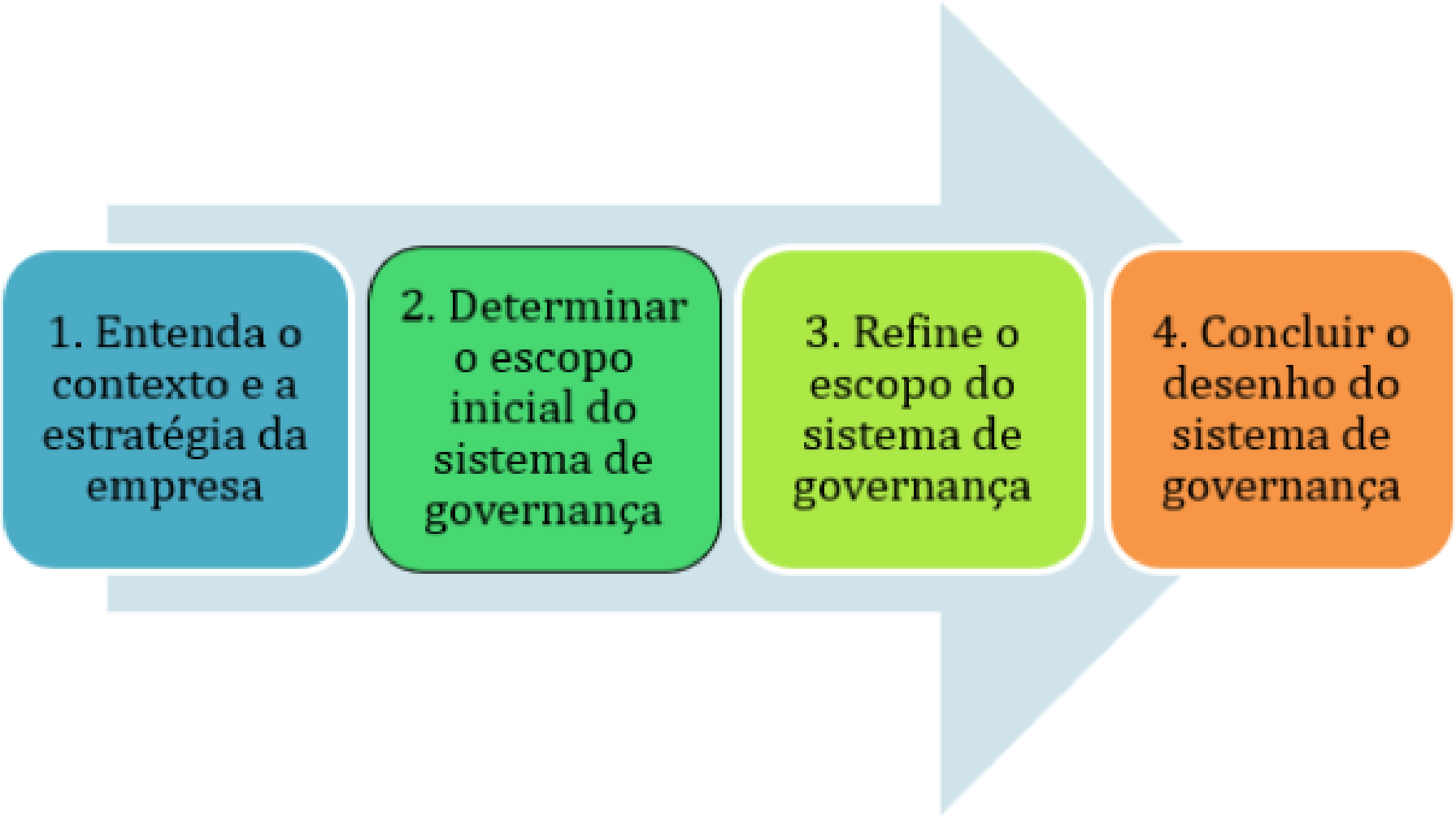
Princípios do *Framework* de Governança

FURB
UNIVERSIDADE DE BLUMENAU

Componentes genéricos e variantes

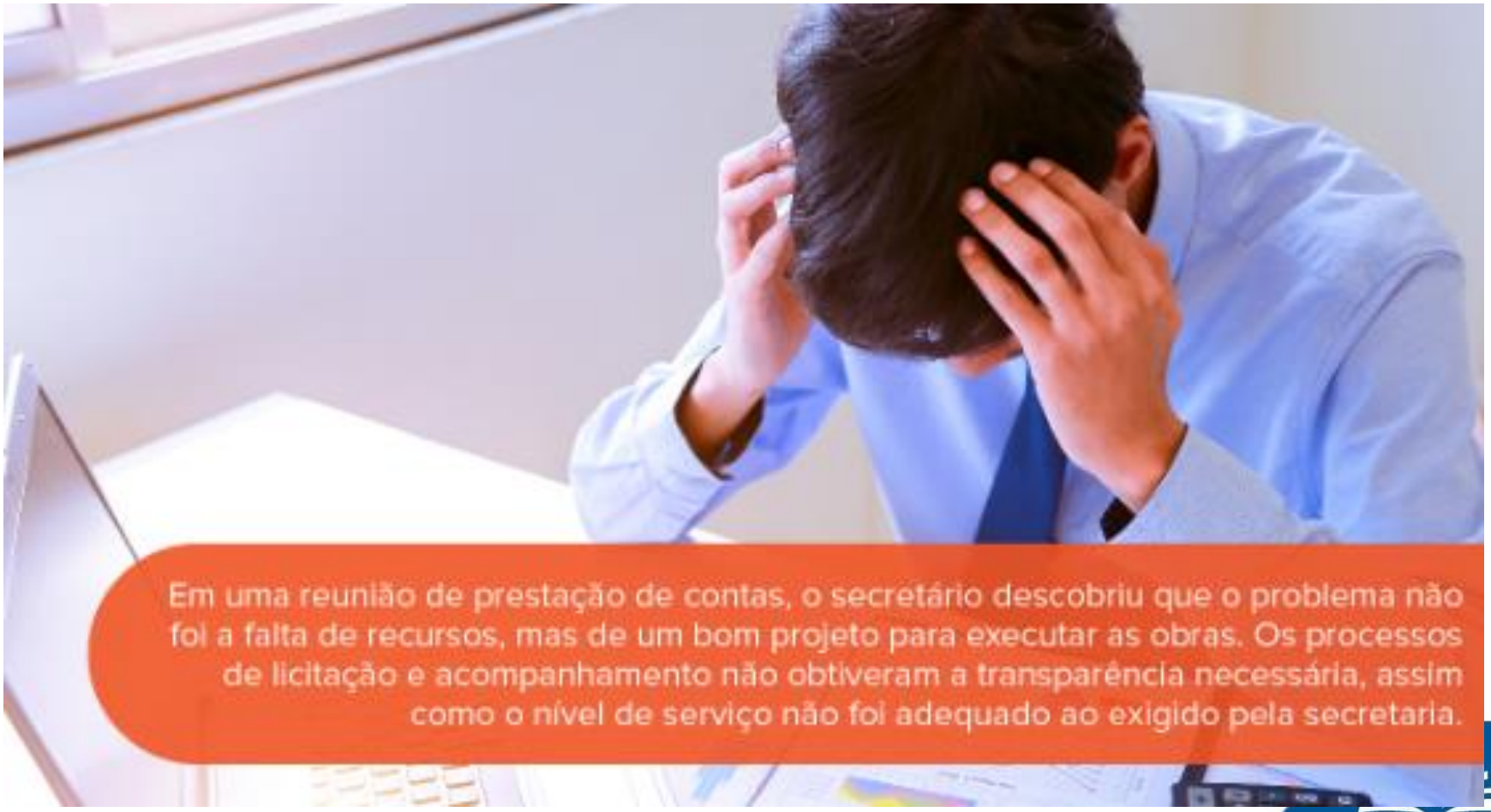


Fluxo de trabalho do projeto do sistema de Governança



Estudo de caso

Estudo de caso



Estudo de caso

Estudo de caso

Estudo de caso

A governança de TI e o Cobit

- A velocidade de adaptação tem que ser muito grande, pois há uma exigência para tal, estamos vivendo a era do nanossegundo.
- A governança em TI deve ficar em consonância com a governança corporativa para melhorar as práticas empresariais focadas no melhor relacionamento da empresa com os seus públicos
- A governança que dará o suporte necessário à empresa para o cumprimento do planejamento estratégico definido pela alta direção

O que os gestores de TI devem buscar

- Avaliar: planejar corretamente as necessidades atuais da empresa e também as projeções de crescimento para que os investimentos cumpram com seu papel, que é a manutenção do nível de serviço desejado pela organização.

O que os gestores de TI devem buscar

- Dirigir: após o planejamento, os gestores responsáveis pela preparação e implementação dos planos e políticas devem fazer cumprir o que foi alocado de recursos para o correto direcionamento proposto pela alta direção.

O que os gestores de TI devem buscar

- Monitorar: devem acompanhar todo o projeto com indicadores de desempenho, para, assim, tomar ações de correção ou melhoria para que a TI fique em conformidade com as necessidades da organização.

O que os gestores de TI devem buscar

- Monitorar: devem acompanhar todo o projeto com indicadores de desempenho, para, assim, tomar ações de correção ou melhoria para que a TI fique em conformidade com as necessidades da organização.

A governança de TI e o Cobit

- O COBIT realiza a integração de outros frameworks publicados pelo instituto, caracterizando-se por ser um conjunto de boas práticas e recomendações de governança em TI.
- Hoje na versão Cobit 2019 mantém a obtenção de resultados pelo investimento destinado à TI nas empresas e otimizando a utilização dos recursos e os níveis de governança planejados.

A governança de TI e o Cobit

- Tem como objetivos centrais ofertar um framework abrangente para otimizar o valor gerado pela TI nas organizações e permitir o gerenciamento da TI de forma transparente e integrada, criando sinergia entre a TI e os demais departamentos da empresa, focada no alcance das metas propostas pela direção da empresa

COBIT

FURB
UNIVERSIDADE DE BLUMENAU